

Real-time questions during class – Claper

- You can use Claper for asking questions during the classes.
- We will answer your questions at the end of the class.
- Go to <https://claper.fi.muni.cz/e/pv210> or <https://claper.fi.muni.cz> and type event code **pv210**.



MUNI

Incident Handling – Case studies

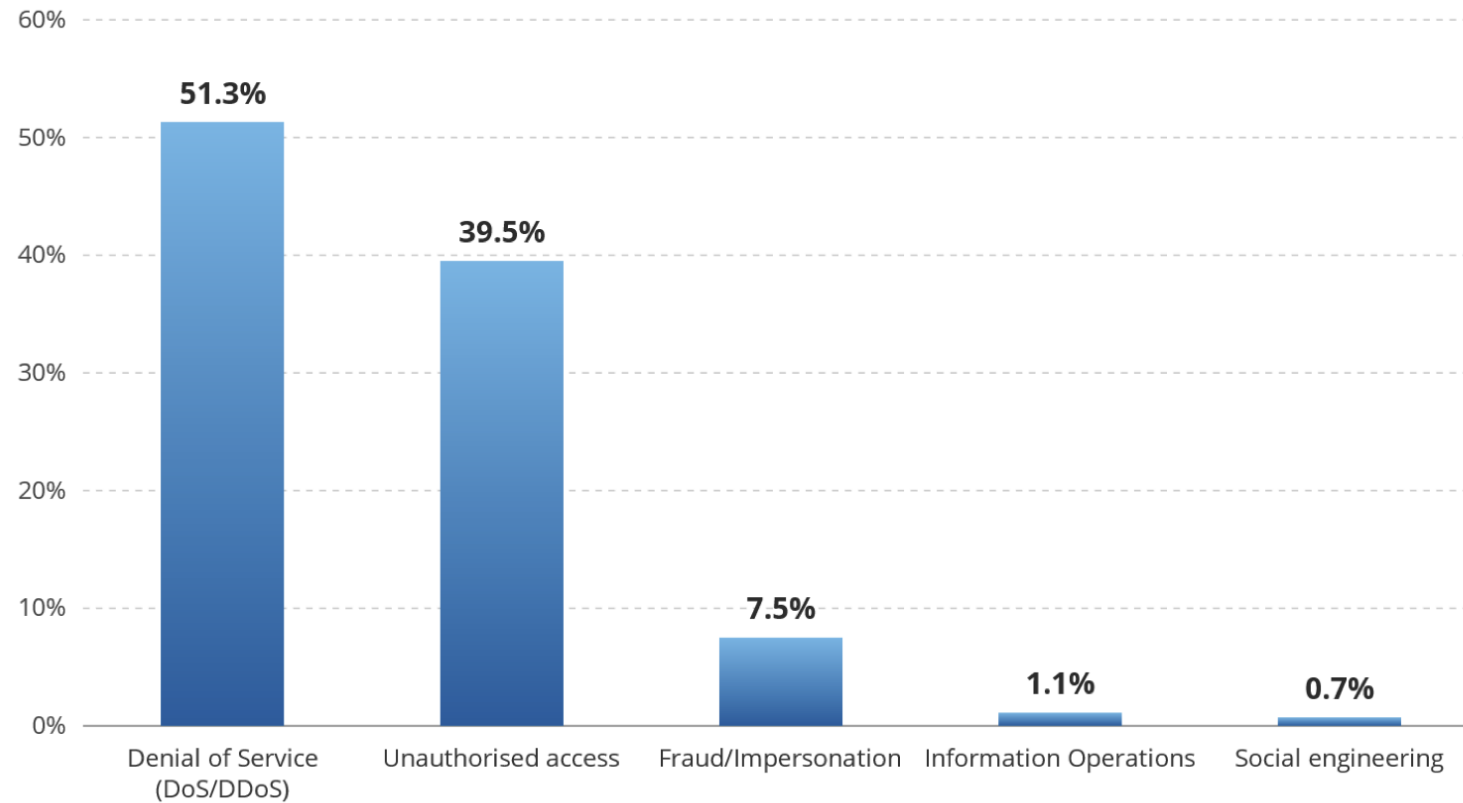
Week 3

PV210 Cybersecurity in an Organization

September 30, 2026

Jan Vykopal

News: ENISA Threat Landscape 2026



Source: ENISA dataset

Source: [ENISA Threat Landscape 2026](#)

Figure 3 - Breakdown of incident types impacting the EU

Agenda

- Exemplary phishing incident handled by CSIRT-MU
- Other phishing attacks against Masaryk University
- Discussion of real past incidents

M U N I

Exemplary Incident – Spear Phishing

PV210 Cybersecurity in an Organization



M U N I
C S I R T - M U

Interactive Incident Resolution

- Real complex incident from MU
- Structure:
 1. Events that happened
 2. Summary in Timeline & discussion – what do you propose to do?
 3. What CSIRT-MU did, what really happened
 4. Repeat

National Cyber and Information Security Agency

- Warning according to Section 12(1) of Act No 181/2014, on cyber security
- [Full text in English](#), [in Czech](#)

- Warning against a cybersecurity threat in the form of an **extensive campaign of cyberattacks on information and communication systems** in the Czech Republic, and on the systems of healthcare facilities in particular. This campaign could have severe impacts on the availability, confidentiality, and integrity of the information in important information and communication systems.
- The Agency has information that **the threat could be carried out in the coming days**, however there are also indications that the preparatory phase of the attacks is already in progress, namely via a **spear-phishing campaign**.
- The National Cyber and Information Security Agency **assesses this threat level as High** – the threat is probable to highly probable.

Timeline – What Next?

- 2020-04-16 12:51 Warning issued and published

[CSIRT-MU] Warning to Administrators

- Sent to a MS Teams group followed by all IT administrators

Varování NÚKIB před hrozbou v oblasti kybernetické bezpečnosti

na základě Varování [1] Národního úřadu pro kybernetickou a informační bezpečnost (vydané dle § 12 odst. 1 zákona č. 181/2014 Sb., o kybernetické bezpečnosti) bychom vás chtěli informovat o předpokládané kampani závažných kybernetických útoků na informační a komunikační systémy v České republice. Toto Varování není pro univerzitu právně závazné, nicméně v rámci prevence kybernetických útoků považujeme za vhodné na Varování reagovat.

[CSIRT-MU] Warning to Users

- [Full text](#)
- Distributed via CSIRT-MU web, IS MU, Inet, Facebook, MS Teams

Warning: Our university could face a massive wave of spear-phishing e-mails in the upcoming days

The cybersecurity team of Masaryk University would like to inform you about an increased risk of being targeted by fraudulent e-mails in upcoming days, so-called spear-phishing. Fraudulent e-mails could also misuse the current situation around the coronavirus pandemic. Given the nature and possible consequences of this situation, we would like to give you more details.

Timeline – What Next?

- 2020-04-16 12:51 NCISA issues and publishes Warning
- 2020-04-16 15:11 CSIRT-MU warns administrators
- 2020-04-16 16:42 CSIRT-MU warns users – Czech version
- 2020-04-16 16:52 CSIRT-MU warning in IS MU in red pop-up
- 2020-04-17 17:28 CSIRT-MU warns users – English version

[Attacker] Phishing Arrives

- Short text written in Czech saying that annual wage plan is available
- URL with **id.muni.cz** subdomain

From: © Masarykova univerzita <Caitrin.Engle@colorado.edu>
Date: April 19th, 2020 17:48:10 SELČ
To: *** <***@***.muni.cz>
Subject: Kalendář plánu mezd 2020 je nyní k dispozici. (důležitý)

Kalendář plánu mezd 2020 je nyní k dispozici.

👉 [hXXp://id\[.\]muni\[.\]cz\[.\]uppermountainrdforshoreandwest\[.\]com](http://hXXp://id[.]muni[.]cz[.]uppermountainrdforshoreandwest[.]com)

© Masarykova univerzita

[Attacker] Phishing Site

The screenshot shows a web browser window with the address bar displaying `http://tronalafia-relnig.org/wp-includes/pomo/workap/muniz.cz.htm`. The page features the MUNI logo and the text "Jednotné přihlášení" (Unified login). The login form contains two input fields: "Učo" (Username) and "Primární heslo" (Primary password). Below these fields is a checkbox labeled "Zapamatovat si mě" (Remember me) and a blue button labeled "PŘIHLÁSIT" (Login). A link "Mám problém s přihlášením" (I have a problem with login) is located below the login form. The footer of the page includes copyright information for Masarykova univerzita and mentions the "Ústav výpočetní techniky MU" (Institute of Computer Science MU).

© Masarykova univerzita
Službu [Jednotné přihlášení MUNI](#) zajišťuje [Ústav výpočetní techniky MU](#)

- Insecure web (HTTP protocol, no certificate)
- Unknown domain
`tronalafia-relnig.org`
- URL indicates Wordpress CMS
`wp-includes`

Timeline – What Next?

- 2020-04-16 12:51 NÚKIB issues and publishes Warning
- 2020-04-16 16:42 CSIRT-MU warns users – Czech
- 2020-04-17 17:28 CSIRT-MU warns users – English
- 2020-04-19 15:02 (Sunday) Phishing site TLS certificate issued
- 2020-04-19 17:47 (Sunday) First phishing emails received at MU

[CSIRT-MU] Actions

- Blocking of phishing site on university DNS servers
- Analysis of network data
 - Any accesses to phishing website from university network?
- Phishing site analysis
 - Phishing site was a copy of source files of university pages
 - **Including loading of CSS and Javascripts from university servers**
- Logs from our servers hosting the files
 - Any accesses with HTTP referrer set to the phishing site?

[CSIRT-MU] Phishing site without CSS

← → ↻ ⓘ Nezabezpečeno | tronalafia-relnig.org/wp-includes/pomo/workap/muniz.cz.htm

[Přejít k přihlášení](#)



[English](#)

- [EN](#)

Vložte své jméno a heslo

Přihlaste se

UČO

Primární heslo

☒ Zapamatovat si mě

- [Mám problém s přihlášením](#)

© Masarykova univerzita
Službu [Jednotné přihlášení MUNI](#) zajišťuje [Ústav výpočetní techniky MU](#)

[CSIRT-MU] Phishing Site Redirected

- Redirect injected into our JavaScript
- If JS is launched on a site outside *muni.cz* domain, then redirect the user to the CSIRT-MU landing page:

Varování: Od pohromy vás možná dělilo jen pár kliknutí

Chyby děláme všichni, útočníky nevyjímaje. CSIRT-MU tentokrát využil chyb útočníků a jejich pokus o phishingový útok neutralizoval. Co přesně to znamená? Uživatelé, kteří obdrží podvrhnutou zprávu a následně kliknou na odkaz, který pro ně útočník nachystal, nebudou přesměrováni na podvrhnutý formulář, jak útočník doufal, ale na toto varování. Pokud jste se tedy na stránku dostali výše zmíněným způsobem, byli jste jen krok od toho, stát se obětí tohoto útoku.

Timeline – What Next?

- 2020-04-19 17:47 (Sunday) First phishing emails
- 2020-04-20 7:39 (Monday) Phishing domain blocked
- 2020-04-20 10:15 Phishing domain CSS removed
- 2020-04-20 11:14 CSIRT-MU informs NCISA about the attack
- 2020-04-20 15:00 Phishing redirected to CSIRT-MU warning page
- 2020-04-20 15:21 CSIRT-MU informs the users/admins who accessed and filled in the phishing site before the redirect set (10 users in total)

[Attacker, MU] User Accounts Abused

- Spam is sending world-wide
- Microsoft blocks all outgoing emails from MU
- Identification of abused accounts
- Log analysis of email servers and IS MU

Timeline – Findings from Forensics Analysis

- 2020-04-20 15:21 Information sent to users/admins
- 2020-04-20 18:56 – 20:54 Attacker read MU guides on how to set up email clients
- 2020-04-20 21:32 – 22:33 Attacker accessed 4 accounts and tried to change password in IS
- 2020-04-20 22:37 Attacker changed password of the 4th account – user1
- 2020-04-20 23:33 – 2020-04-21 7:22 Attacker sent 43,648 emails from user1 account
- 2020-04-21 12:24 User1 changes his/her password
- 2020-04-22 21:55 Attacker accesses 3 more accounts in IS
- 2020-04-22 21:57 Attacker changes password of another account – user2
- 2020-04-22 – 2020-04-24 Attacker sent 50,243 emails from user2 account
- **Forensic findings are marked red, CSIRT did not have this information during the ongoing attack.**

Timeline – What Next?

- 2020-04-20 23:33 – 2020-04-21 7:22 Attacker sent 43,648 emails from user1 account
- 2020-04-22 – 2020-04-24 Attacker sent 50,243 emails from user2 account
- 2020-04-24 22:33 (**Friday**) Microsoft blocked all university email communication but didn't tell
- 2020-04-25 ~8:00 (**Saturday**) Infrastructure administrators start working on the email outage

[MU] Actions

- Identification of abused accounts and their blocking
- Disaster recovery to find out why emails do not work and fix it
- Escalation to university management
 - The incident disrupted important service and affected all users
- Gathering and analysis of network data, logs
 - Activity of the attacker on abused accounts
 - Forensics analysis – joined data from network activity (CSIRT-MU), IS MU (CVT FI), webserver (webadmins ICS), mailserver (infrastructure admins ICS), unified MU login (CSIRT-MU)
- CSIRT played an important role in incident response coordination

Timeline – What Next?

- 2020-04-24 22:33 (Friday) Microsoft silently blocks all university email communication
- 2020-04-25 8:34 (Saturday) Accounts of user1 and user2 blocked
- 2020-04-25 17:30 Email infrastructure recovered, sending emails unblocked by Microsoft
- 2020-04-27 10:14 CSIRT-MU analyses logs from IdM, mailservers and webservers
- 2020-04-27 13:03 head of Infrastructure division provides executive summary for management
- 2020-04-29 14:35 CSIRT-MU analyses logs from IS MU, propose identification of other compromised accounts

[CSIRT-MU] Findings

- Attacker only changed passwords in IS and used the accounts to send spam
 - No other activity found on other MU services
 - Attacker was using Czech version of IS
- Both *user1* and *user2* clicked on phishing and filled in their credentials
- Attacker got access to 5 more accounts from this phishing campaign, but did not use them (or their use was not noticed)

Why did Microsoft block us?

- Administrative changes in the server's settings the week before the attack
 - Bug in audit log caused the storing author of the changes as „unknown“
 - Detection triggered and reported compromised administrator account
- Multiple accounts used for a massive spam campaign
 - Another detection triggered and reported abuse
- In a normal scenario, only the abused accounts would be blocked
- Combination of both detections led to blocking of the whole organization (MU)
- An example of the severe impact of automated blocking triggered by false positive detection

Timeline – What Next?

- 2020-04-29 14:35 CSIRT-MU analyses logs from IS MU, propose identification of other compromised accounts
- 2020-04-30 9:22 IS MU team identifies 5 more accounts accessed by attacker but not abused, reset all their passwords
- 2020-04-30 20:46 Attacker access another account and changes password
- 2020-05-01,02,03 Public holiday and weekend
- 2020-05-04 17:14 Attacker access another account and changes password

[CSIRT-MU] Actions

- All accounts manipulated by attacker secured
- CSIRT-MU continues to analyze all available data
- 7 accounts confirmed to be compromised by the phishing
- 8 more accounts accessed by attacker
 - 3 of them with no direct connection to the phishing (from our point of view)
 - Users probably filled the phishing at home
- Detailed summary written for university top management
- Report of the incident sent to NCISA

Timeline – What Next?

- 2020-05-04 17:14 Attacker accessed another account and changed the password
- 2020-05-05 CSIRT-MU and IS MU identified all accounts accessed by any IP address used by attackers in the past. All passwords are reset.
- 2020-05-11 11:05 Detailed summary sent to university management, incident closure.

Can We Locate the Attacker?

- He/she used Czech version of IS
- He/she attacked on weekends and outside office hours of our UTC+2 time zone and outside Czech public holidays
- Spam sent from a server in the USA
- Manipulation with accounts from multiple IPs in Nigeria
 - All registered at [17 Chris Alli Cres, Lagos](#)

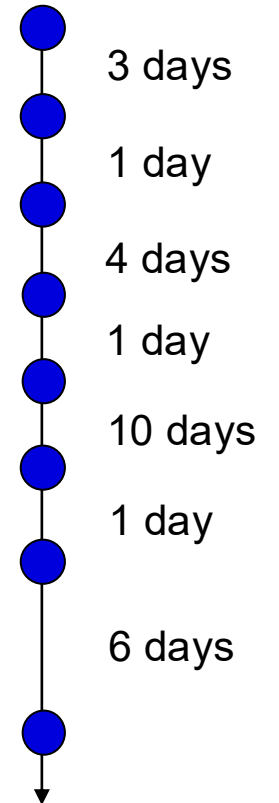


Timeline Summary – a Month of Work

- 2020-04-16 12:51 NCISA issues and publishes Warning
- 2020-04-19 17:47 (Sunday) First phishing emails received at MU
- 2020-04-20 15:21 CSIRT-MU informs the potentially compromised users/admins
- 2020-04-24 22:33 (Friday) Microsoft silently blocks all university email communication
- 2020-04-25 17:30 Email infrastructure recovery, sending emails unblocked by Microsoft
- 2020-05-04 17:14 Attacker access another account and changes password
- 2020-05-05 CSIRT-MU and team IS MU identifies all accounts accessed by any IP attacker used in the past. All account's passwords reset.
- 2020-05-11 11:05 Detailed summary sent to university management, incident closure.

Is the incident really over?

There might be another account the attacker got credentials for but has not accessed yet



Six Months Later...

- U.S. Department of Justice official requested help from the Czech Republic with the investigation of a public institution bank account fraud
- Handled by NCOZ SKPV* unit of the Czech Police
 - Czech national contact point for cybercrime
- **2020-10-20** NCOZ requests the cooperation from MU pursuant to the provisions of §18 of Act no. 273/2008 Sb. about the Police of the Czech Republic

* Národní Centrála proti Organizovanému Zločinu – Služba Kriminální Policie a Vyšetřování

Police Investigation

- Evidence leads to the MU mail server and the MU account
- Email account of *user2* was abused for a financial scam
 - 50200+ sent spam emails were only a smoke screen to cover another illegal activity
 - Virtually impossible to discover a few fraudulent e-mails among thousands of others
- CSIRT-MU hands the attack analysis details to the Police
 - We would not have the data after 6 months (log rotate, data retention periods) unless the impacts of the attack were so high
 - In this case, the investigation results were archived, and we were able to provide them on a legal request

Summary – role of a CSIRT

- Coordination of incident response inside the organization
 - A particular incident may require ad-hoc solution (Javascript redirect, CSS blocking)
- CSIRT deploys traffic monitoring and requires log collection, which enabled tracking of affected users and attacker's actions
- Following regulations related to incident response (data retention)
- Communication with external parties (such as police)

Other Phishing Attacks Against Masaryk University

Introduction

- Deep dive into phishing campaigns, one of the severe threats universities face
- Results of the investigation that took several months during the summer 2023
 - Discovered activities still relevant today
 - All attacks presented here are attributed to the same actor → can be considered as Advanced Persistent Threat (APT)
- APT attacks lasted more than 4 years
- Specific examples of activities:
 1. Attacks against Masaryk University → account compromise
 2. Misuse of compromised university accounts for further attacks
 3. Tracing the attacker

What is the Attacker Targeting?

- **Employee payroll is sent every month by Inet MU**
- MU had ~7000 employees at that time
- Almost every employee checks their payroll every month
- Spear-phishing imitating that can have great success

Month	Number of payroll visits in Inet
October 2022	6388
November 2022	6621
December 2022	6808
January 2023	6872
February 2023	6111
March 2023	6381
April 2023	6232

1. 7. 2020 – Phishing Mail

- Spear-phishing from compromised accounts at the Universiteit van Amsterdam, Netherlands
- Topic – salaries
- Poorly spoofed sender
- **URL hidden under an HTML link**, so that the user see a legitimate domain
- Real context (muni.islogin, istech, FI MU)

From: admin.istech@Masaryk University <[REDACTED]@uva.nl>
Subject: Nové oznámení týkající se vaší mzdy 2020
To: <@ipe.muni.cz>
Date: Wed, 1 Jul 2020 12:36:59 +0000

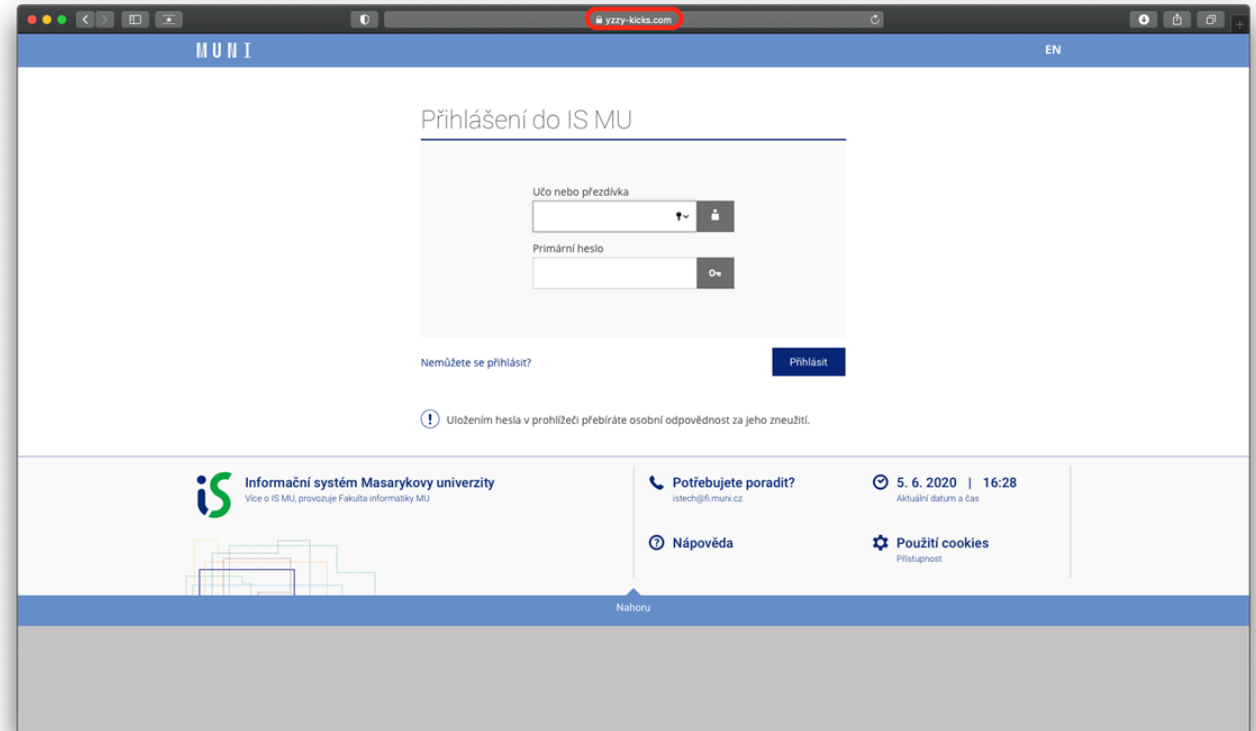
Vážení@ipe.muni.cz

[https://muni.islogin\[.\]cz/UI/payr011/2020/F0rm.pdf](https://muni.islogin[.]cz/UI/payr011/2020/F0rm.pdf)
([https://www.orgexamresultdel15\[.\]in/Muni/muni.htm](https://www.orgexamresultdel15[.]in/Muni/muni.htm))

Informační systém Masarykovy univerzity Více o IS MU,
provozuje Fakulta informatiky MU

1. 7. 2020 – Phishing Site

- 1:1 copy of MU study Information System login page
- Site footer is static
 - Fixed date „5. 6. 2020 16:28“
 - The attacker planned and prepared this attack for almost a month!
- **Site uses HTTPS**
- Domain does not try to imitate a legitimate *muni.cz* domain



8. 10. 2020 – Phishing Mail (3 Months Later)

- Spear-phishing from compromised accounts at Masaryk University
- **Topic – account cancellation**
- **Sender spoofed** to another user
- URL hidden under an HTML link, so that the user see a legitimate domain

```
From: Muni.cz Technická služba <[REDACTED]@czs.muni.cz>  
To: @fi.muni.cz  
Subject: Žádost o ukončení 8. října 2020  
Date: Thu, 08 Oct 2020 04:17:51 +0000  
  
Hi ,  
  
Vezměte prosím na vědomí, že žádost o pozastavení vašeho e-  
mailu  
@fi.muni.cz byl odeslán za méně než 48 hodin,  
Náš tým Muni.cz zahájil proces,  
Požádáme vás o potvrzení vašich údajů k této žádosti zrušení.  
  
Requet zrušit hned <  
http://Fi46.Fic108.zivantobuilders\[.\]com/>  
s pozdravem,  
  
Muni.cz Online Service center. © 2020Muni
```

8. 10. 2020 – Phishing Site

- 1:1 copy of MU study Information System login page
- Site footer is static
 - Fixed date „5. 6. 2020 16:28“
 - The **same time as in July attacks**
- **The site does not use HTTPS**
- Domain does not try to imitate a legitimate muni.cz domain

The screenshot shows a web page with a blue header bar containing the text "MUNI" on the left and "EN" on the right. The main heading is "Přihlášení do IS MU". Below this is a login form with two input fields: "Učo nebo přezdivka" (Username or nickname) and "Primární heslo" (Primary password). Each field has a small icon to its right: a lowercase 't' for the username field and a lowercase 'g' for the password field. Below the form, there is a link "Nemůžete se přihlásit?" and a blue button labeled "Přihlásit". A warning message in red text states: "Uložením hesla v prohlížeči přebíráte osobní odpovědnost za jeho zneužití." The footer contains a logo for "iS" (Informační systém Masarykovy univerzity) and text "Více o IS MU, provozuje Fakulta informatiky MU". To the right of the logo are four links: "H Potřebujete poradit? istech@fi.muni.cz", "Z 5. 6. 2020 | 16:28 Aktuální datum a čas", "K Návodě", and "I Použití cookies Přístupnost".

27. 10. 2020 – Phishing Mail (19 Days Later)

- Spear-phishing from compromised accounts at Palacký University in Olomouc, Czechia
- Topic: salaries
- Poorly spoofed sender
- URL hidden under an HTML link, so that the user see a legitimate domain
- **New MU logo used**

From: "(ceitec.muni.cz)" <[redacted]@upol.cz>
Subject: ceitec.muni.cz_Notification:(Tuesday, October 27, 2020)
To: <@ceitec.muni.cz>
Date: Tue, 27 Oct 2020 10:24:50 +0000

2 Nové oznámení týkající se vašich mezd 2020
[https://is.muni\[.\]cz/cz/Výplatní páska/2020/form.pdf](https://is.muni[.]cz/cz/Výplatní_páska/2020/form.pdf)
([http://xx25.xx850.abchellas.mimunch\[.\]site/](http://xx25.xx850.abchellas.mimunch[.]site/))
(c) 2020 Masaryk Univerzita
webmaster-up@muni.cz

Od: Masarykova univerzita Informační systém <[redacted]@upol.cz>
Předmět: 27. pondělí říjen 2020
Datum: 27. října 2020 10:16:23 SEČ
Komu: [redacted]

MUNI Masarykova
univerzita

2 Nové oznámení týkající se vašich mezd 2020

[https://is.muni.cz/cz/Výplatní páska/2020/form.pdf](https://is.muni.cz/cz/Výplatní_páska/2020/form.pdf)

(c) 2020 Masaryk Univerzita

webmaster-up@muni.cz

MUNI
ICS

27. 10. 2020 – Phishing Site

- 1:1 copy of MU study Information System login page
- Site footer is static
 - Fixed date „5. 6. 2020 16:28“
 - The **same time as in July and October attacks**
- The site does not use HTTPS
- Domain does not try to imitate a legitimate muni.cz domain

The screenshot shows a web page titled "Přihlášení do IS MU" (Login to IS MU). At the top, there is a blue header with the text "MUNI" on the left and "EN" on the right. The main content area contains two input fields: "Učo nebo přezdívká" (Username or nickname) and "Primární heslo" (Primary password). Below these fields, there is a link "Nemůžete se přihlásit?" (You cannot log in?) and a blue button labeled "Přihlásit" (Login). A warning message states: "Uložením hesla v prohlížeči přebíráte osobní odpovědnost za jeho zneužití." (By saving the password in the browser, you assume personal responsibility for its misuse). The footer contains the logo of the Masaryk University of Informatics (iS) and the text "Informační systém Masarykovy univerzity" (Information system of Masaryk University). It also includes a contact link "Potřebujete poradit?" (Need help?) with the email "istech@fi.muni.cz", a navigation link "Nápověda" (Help), and a date/time stamp "5. 6. 2020 | 16:28" (Actual date and time). A link to "Použití cookies" (Cookie usage) is also present.

5. 11. 2020 – Phishing Mail (9 Days Later)

- Spear-phishing from compromised accounts at Palacký University in Olomouc, Czechia
- **Topic: mail account issue**
- Poorly spoofed sender
- E-mail obfuscated HTML code to avoid automatic detection
- Very poor Czech (poor auto-translate?)
- New MU logo

From: Muni.cz Informační systém [REDACTED]@upol.cz

Subject: Je vyžadována akce: Čtvrtek 5. listopadu 2020

To: <lastovicka@ics.muni.cz>

Date: Tue, 27 Oct 2020 10:24:50 +0000

e-mailový účet nebyl v naší databázi nalezen.

Nyní klikněte sem "Opravte problém"

a vyhněte se zrušení e-mailu.

S pozdravem.

MUNI-Podpěra,

Podpora

```
</style>
<p></p>
<p>&nbsp;</p>
<p>V<sub>lastovicka</sub>a<sub>a<sub>lastovicka</sub>š<sub>lastovicka</sub>
<sub>lastovicka</sub>e-
m<sub>lastovicka</sub>a<sub>a<sub>lastovicka</sub>i<sub>lastovicka</sub>l<sub>lastovicka</sub>o<sub>l
astovicka</sub>v<sub>lastovicka</sub>y<sub>lastovicka</sub>
<sub>lastovicka</sub>ú<sub>lastovicka</sub>č<sub>lastovicka</sub>e<sub>lastovicka</sub>t<sub>la
stovicka</sub>
<sub>lastovicka</sub>n<sub>lastovicka</sub>e<sub>lastovicka</sub>b<sub>lastovicka</sub>y<sub>la
stovicka</sub>l<sub>lastovicka</sub>
<sub>lastovicka</sub>v<sub>lastovicka</sub>
<sub>lastovicka</sub>n<sub>lastovicka</sub>a<sub>lastovicka</sub>š<sub>lastovicka</sub>i<sub>la
stovicka</sub>
.....
```

5. 11. 2020 – Phishing Site

– Again, exactly the same

MUNI

EN

Přihlášení do IS MU

Učo nebo přezdívká

t

Primární heslo

Q2

Nemůžete se přihlásit?

Přihlásit

! Uložením hesla v prohlížeči přebíráte osobní odpovědnost za jeho zneužití.

iS

Informační systém Masarykovy univerzity
Více o IS MU, provozuje Fakulta informatiky MU

H

Potřebujete poradit?
istech@fi.muni.cz

Z

5. 6. 2020 | 16:28
Aktuální datum a čas

K

Nápověda

l

Použití cookies
Přístupnost

12.-20. 7. 2022 – Phishing Mail (2 Years Later)

- 6 waves of spear-phishing from compromised accounts at :
 - LSU Health Sciences Center, New Orleans, USA
 - Golf club Kanagawa, Japan
 - Universidade do Minho, Portugal
- Topic: salaries
- Poorly spoofed sender
- URL hidden under an HTML link, so that the user see a legitimate domain
- **Old MU logo used**

Předmět: Nová aktualizace mezd pro: <csirt-info@muni.cz>
Od: "Administrativní oznámení" - [REDACTED]@med.uminho.pt>
Datum: Sat, 16 Jul 2022 01:12:00 +0800
Komu: csirt-info@muni.cz

Nová aktualizace mezd pro: <csirt-info@muni.cz>



Příjemce: <csirt-info@muni.cz>

2 Nové oznámení týkající se vaší mzdy za rok 2022
<https://www.muni.cz/cz/Payr0ll/2022/f0rm.pdf>

© 2022 Masarykova univerzita

12.-20. 7. 2022 – Phishing Site

- 1:1 copy of MU study Information System login page
- Site footer is static
 - Fixed date „5. 6. 2020 16:28“
 - **The same time as in 2020 attacks!**
 - In the 2nd to last wave, they updated the footer to a new fixed date „18. 7. 2022 12:34“
- The site does not use HTTPS
- Domain does not try to imitate a legitimate muni.cz domain

MUNI EN

Přihlášení do IS MU

Učo nebo přezdívka

Primární heslo

Nemůžete se přihlásit? Přihlásit

! Uložením hesla v prohlížeči přebíráte osobní odpovědnost za jeho zneužití.

iS Informační systém Masarykovy univerzity
Více o IS MU, provozuje Fakulta informatiky MU

H Potřebujete poradit?
istech@fi.muni.cz

K Nápověda

I Použití cookies
Přístupnost

18. 7. 2022 | 12:34
Aktuální datum a čas

Nahoru

23. 11. 2022 – Phishing Mail (4 Months Later)

- Spear-phishing from compromised accounts at Universidad de Granada, Spain
- **Topic: important message for employees**
- Poorly spoofed sender
- URL hidden under an HTML link, so that the user see a legitimate domain

From: Masarykova Univerzita <[REDACTED]@ugr.es>
To: @law.muni.cz
Subject: Přečtěte si prosím: Důležitá zpráva z Masarykova Univerzita
Sent: Wednesday, November 23, 2022 1:52 PM

Vážený zaměstnanci,
Nová důležitá zpráva z portálu pro zaměstnance.
Přečtěte si zprávu.
([https://keratomx\[.\]tk/osa/mail.law.muni.cz.html](https://keratomx[.]tk/osa/mail.law.muni.cz.html))
Děkuji
Masarykova Univerzita

From: Masarykova Univerzita <[REDACTED]@ugr.es>
Sent: Wednesday, November 23, 2022 1:42 PM
To:
Subject: Přečtěte si prosím: Důležitá zpráva z Masarykova Univerzita

Vážený zaměstnanci,
Nová důležitá zpráva z portálu pro zaměstnance.
Přečtěte si zprávu.

Děkuji
Masarykova Univerzita

23. 11. 2022 – New phishing site

- The site **does not reflect reality at all**
- The only real part is the logo of the Faculty of Arts
- Despite that, we have confirmed a **breach of 8 user accounts** by this phishing!



MUNI
FILOZOFICKÁ
FAKULTA

Služba bude ukončena k 31.12. 2022.

Username

Password

English (US)

LOGIN

FFMU

Pošta Office 365 - outlook.office.com

15. 12. 2022 – Phishing Mail (3 Weeks Later)

- **Technically perfect spear-phishing** from compromised accounts at Universidad de Granada, Spain (same as in November)
- **Topic: voice mail**
- Attachment:  **Voice Mail (1.28mins).html**
 - Visually perfect copy of the MU login page
 - Every user has a pre-filled name (i.e., a different attachment sent for each user)
 - Button sends the filled data to the attacker's server
 - Confirmed compromise of 42 user accounts

From: "Audio Center" <[REDACTED]@ugr.es>

Subject:  Voice Mail (1:28mins)

To: <@mail.muni.cz>

Date: Thu, 15 Dec 2022 09:57:17 -0800

----- Voicemail Summary -----

Voice time: 1:28mins (847kb.)

Voice Date: 12/15/2022 9:41 AM

MUNI Jednotné přihlášení

[English](#) [ua Українська](#)

uČo

Primární heslo

☐ Zapamatovat si mě

PŘIHLÁSIT

[Mám problém s přihlášením](#)

13.–25. 7. 2023 Phishing Mail (7 Months Later)

- 2 waves of spear-phishing from compromised accounts at the University of the Basque Country, Spain
- **Topic: salaries**
- Again, the same phishing site with the date „18. 7. 2022 12:34“
- Confirmed compromise of 2 user accounts
 - Both cases involved students without employment, who clicked on payroll...

Masarykova univerzita vám poslala další dvě zásadní zprávy týkající se vašeho mzdového kalendáře na rok 2023.

[*Pro zobrazení naleznete tento odkaz.* | [https://dawat610\[.\]com/muni.cz/](https://dawat610[.]com/muni.cz/)]

S pozdravem

Masarykova Univerzita

Dvě nová oznámení týkající se vaší mzdy za rok 2023

[*<https://muni.cz/cz/Payr011/2023/f0rm.pdf>* | [https://adesa-peru\[.\]org/muni/stel.htm](https://adesa-peru[.]org/muni/stel.htm)]

© 2023 Masarykova univerzita

17. 10. 2024 Phishing Mail (15 Months Later)

- Spear-phishing from compromised accounts at the University of Regensburg, Germany
- **Topic: meeting reminder**
- No spoofed sender
- URL hidden under an HTML link, so that the user see a legitimate domain

Od: "██████████" <██████████@chemie.uni-regensburg.de>
Datum: Thu, 17 Oct 2024 15:46:10 +0200
Předmět: 1 novou zprávu o schůzce

Máte 1 novou zprávu o schůzce

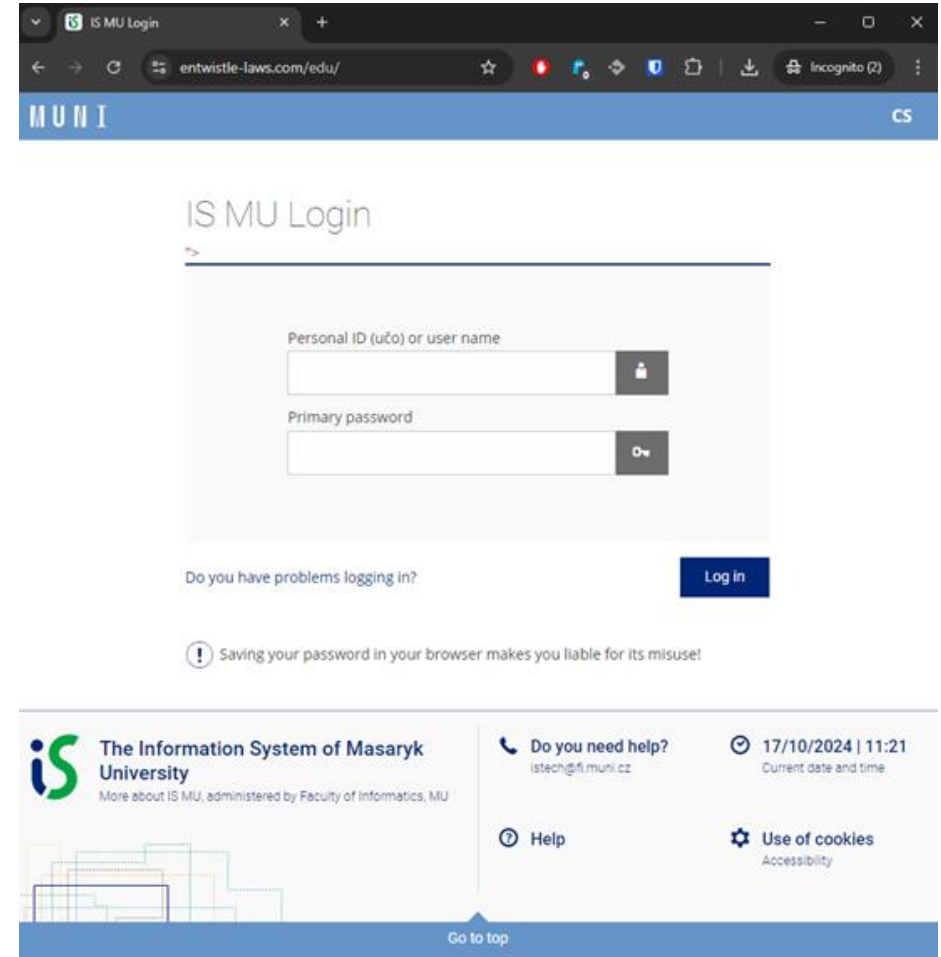
Zobrazit zde

Blackboard | IT služby

Plánovaná zpráva

17. 10. 2024 – Phishing Site

- 1:1 copy of MU study Information System login page
- Site footer is static
 - Fixed date „17. 10. 2024 11:21“
- Site uses HTTPS
- Domain does not try to imitate a legitimate muni.cz domain



23. 10. 2024 Phishing Mail (1 Week Later)

- Spear-phishing from compromised accounts at a construction company in Japan
- **Topic: meeting reminder**
- Poorly spoofed sender
- URL hidden under an HTML link, so that the user see a legitimate domain

Datum: Wed, 23 Oct 2024 15:25:30 +0000

Od: "IT-Support22b6d08ce0c78203fabddd5687a2bcd734dbbcb105025aa8411c62ce337cd95c82c40085" <[REDACTED]@e-sato-k.com>

Předmět: Je vyžadována akce

Komu: csirt@muni.cz

Máte 1 novou zprávu o schůzce

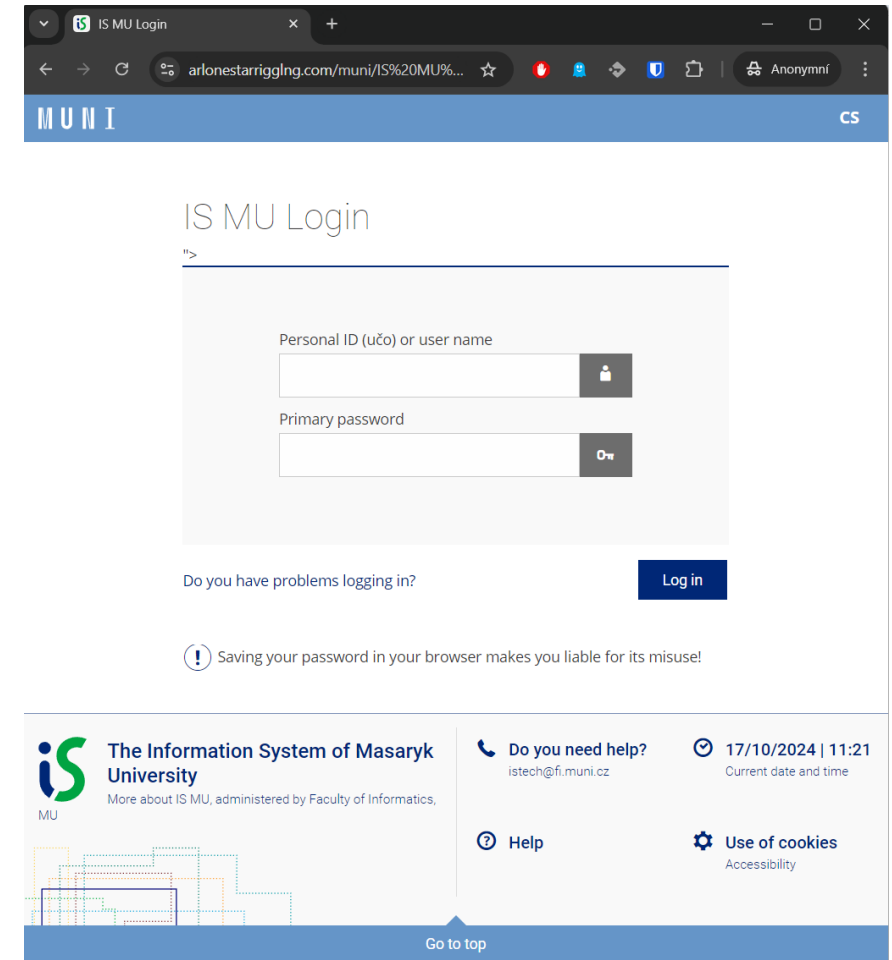
Zobrazit zde

Blackboard | IT služby

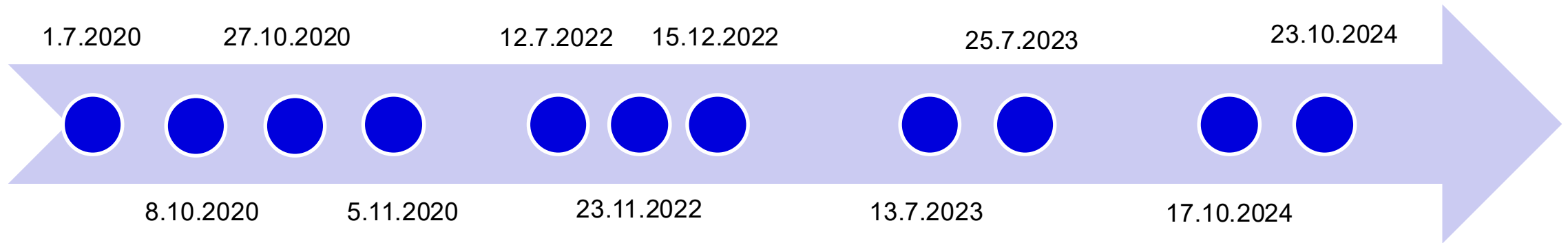
Plánovaná zpráva

23. 10. 2024 – Phishing Site

- 1:1 copy of MU study Information System login page
- Site footer is static
 - Fixed date „17. 10. 2024 11:21“, same as the week before
 - New phishing domain
- Site uses HTTPS
- Domain does not try to imitate a legitimate muni.cz domain



Timeline



Attacks From Masaryk University

Outgoing Phishing

- Coming from user accounts at MU compromised in the attacks described before
- The content was almost the same
- Translated into the language of the targeted country
- Attacks against the Academy of Sciences in Czechia, universities in Czechia, Germany, the Netherlands, Finland, France, and Japan

Phishing Samples

Je hebt nog 1 melding ontvangen met betrekking tot je payrollkalender 2022.

Bekijk nu uw melding [https://data.enday\[.\]jp/Science-ru-nl/](https://data.enday[.]jp/Science-ru-nl/)

Groeten,

© 2022 Radboud University

Faculteit der Natuurwetenschappen

Subject: All inactive accounts are removed due to database congestion

All inactive accounts are removed due to database congestion

ユーザー名: flywing@cb3.so-net.ne.jp

データベースの輻輳により、非アクティブなアカウントはすべて削除されます。

アカウントが無効にならないようにするには、以下のリンクをクリックしてください。

[https://dawat610\[.\]com/so-net.ne.jp](https://dawat610[.]com/so-net.ne.jp)

よろしく

So-net.jp テクニカルチーム

Server Security Alert

Emails are pending and can't be delivered to your inbox folder due to shortage of storage space.

Please clear your emails inbound storage to deliver mails to your mailbox.

Clear clustered mails [https://glamdust\[.\]ch/wp-includes/pomo/plural#<e-mail cile phishingu>](https://glamdust[.]ch/wp-includes/pomo/plural#<e-mail cile phishingu>)

NOTE: Pending emails may be deleted if clustered mails are not cleared.

This message and any associated attachments are confidential. For more information, please

click here [https://glamdust\[.\]ch/wp-includes/pomo/plural#<e-mail cile phishingu>](https://glamdust[.]ch/wp-includes/pomo/plural#<e-mail cile phishingu>)

„Call :534-770-**** has made 1 New attempt to reach you at 05:05:04 PM.



Refer to file to listen“

Attacker Techniques

Scenario 1

- 1. Base of operations in the Microsoft cloud**
- 2. Connect to the university VPN using a compromised account**
- 3. SMTP connection to the university mail server and sending phishing**

Scenario 2

- 1. Base of operations in the Microsoft cloud**
- 2. Connect to the university VPN using a compromised account**
3. Scan of port 22 of the university network
4. Connect to the university SSH server using a different compromised account
- 5. SMTP connection to the university mail server and sending phishing**

Attacker Actions

- Confirmed and documented attacks from MU:
 - *Maybe even earlier...*
 - 29. 11. 2022 sending phishing from server monoceros.physics.muni.cz
 - 6. 12. 2022 sending phishing from server monoceros.physics.muni.cz
 - 22. 3. 2023 sending phishing from server monoceros.physics.muni.cz
 - 15. 5. 2023 sending phishing from server monoceros.physics.muni.cz
 - 6. 6. 2023 sending phishing from server elanor.sci.muni.cz
 - 28. 6. 2023 sending phishing from server arethusa2.fi.muni.cz
 - 13. 7. 2023 sending phishing from server arethusa2.fi.muni.cz
 - 25. 7. 2023 sending phishing from server arethusa2.fi.muni.cz
 - 9. 8. 2023 sending phishing from server minas.ics.muni.cz
- In all cases, the attack followed exactly the same steps described on the previous slide

Attacker Techniques – Forensics Analysis Results

- On the target SSH server:
 - Creation of phishing mail from templates and logos
 - Lists of phishing recipients (text files with 40–150 thousands of email addresses)
 - Mail sending script
- They do not care for anything else on the server (or they perfectly hid it)
 - No persistence or backdoors created
 - No interest in data (in one case, they abused university data storage, did not access the data)
 - No malware installed
 - No lateral movement in the network (except the SSH scan)
 - The attackers did not delete history or their scripts and templates

Attacker Perspective

- Why?

- They farmed thousands of valid accounts from universities and scientific institutions, only to use them to get more accounts...

- Where is the monetization?

- What is the end goal?

Defender Perspective

- What can organisations do to prevent such activities?
- Technical measures?
 - **Should students or employees be able to send >1 e-mail per second?** (>1 per minute?)
 - Do we have MFA (multi-factor authentication) capabilities? **Can we enforce MFA on all users?**
- Process measures?
 - **Reporting to management**, when, how often?
 - **Response coordination** – solved as multiple separate incidents, with no one really connecting the dots.
Who should be that one? Géant CERT? Network of national SOC's according to NIS2?
- User education?
 - How to **train users** not to click on links and not to fill in their credentials?
 - **Mandatory** cybersecurity **courses**? **Simulated phishing campaigns**?

Discussion of real past incidents

Goal of this exercise

- Propose how a CSIRT could react
- Realize different incidents may require different approaches and resolution

Let's start – Incident 1

- Read the [summary of Incident 1 in IS MU](#).
- Time limit: 5 minutes

Discuss preventive and reactive measures

- Pair up with a student next to you.
- Discuss in pairs **what a CSIRT could do to prevent and mitigate the incident.**
- Consider what measures to take to prevent the incident.
- Who should be notified about the incident, and what can be done?
- Write down your ideas, you will need them in the next phase.
- Time limit: 5 minutes

Summary of Incident 1 – Data breach

- Perspective: university CSIRT
- Possible actions:
 - Notify the persons whose data were leaked
 - Report the incident to the top management
 - *Report the leak of personal data to data protection officer (and the national regulatory authority)*
 - File a criminal complaint to police
 - Start penetration testing of web applications and databases
 - Share lessons learned within the organization (training other administrators and staff)
 - Share lessons learned in CSIRT communities
- Anything else?

Incident 2

- Read [summary of Incident 2 in IS MU](#).
- Time limit: 5 minutes

Discuss preventive and reactive measures

- Pair up with a student next to you.
- Discuss in pairs **what a CSIRT could do to prevent and mitigate the incident.**
- Consider what measures to take to prevent the incident.
- Who should be notified about the incident, and what can be done?
- Write down your ideas, you will need them in the next phase.
- Time limit: 4 minutes

Summary of Incident 2 – Cryptocurrency mining

- Perspective: Research & Education CSIRT
- Possible actions:
 - Remove attacker access (change compromised credentials, clean backdoors)
 - Forensic analysis of all affected systems
 - *Educate administrators on password and access policy* – there were compromised keys without passphrase
 - Setup detection mechanisms
 - Share discovered IoC with the community of similar HPC providers
 - File a criminal complaint to police
- Anything else?

Discuss the difference between incidents

- Discuss the **differences** between the two incidents.
- What could a CSIRT do to prevent and mitigate the incident?
- Time limit: 5 minutes

Differences between incidents

Incident 1:

- Scope of a single organization.
- Custom (in-house) application attacked.
- Personal information leaked.

Incident 2:

- Multiple organizations involved.
- Standard common service (SSH) attacked. A known vulnerability exploited (CVE-2019-15666).
- Misuse of R&D infrastructure and resources for financial gain. DoS for legitimate users.
- Same: reporting to authorities, informing users.

More incidents – reading

- [CSIRT.CZ: příběhy z patnácti let boje za bezpečný internet v Česku](#) (in Czech)

Invitation to Incident Response Simulation

- Think you can outsmart a real-world threat actor? Prove it!
- **What:** ThreatSpace Cyber Drill, a hands-on Capture The Flag (CTF) competition where you step into the shoes of a Security Operations Center (SOC) analyst.
- **When:** October 16, 2026, 11:00-12:00 CET
- Available only to universities participating in the Google.org Cybersecurity Seminars (such as Masaryk university).
- [Registration form](#)

Questions, answers, and feedback in Claper

- You can use Claper for asking questions during the classes.
- We will answer your questions at the end of the class.
- Go to: <https://claper.fi.muni.cz/e/pv210>
- **Please provide us with feedback:**
How can today's class be improved?

